

VIDAR & LUMMA STEALER

Analisi tecnica di una catena loader → infostealer multi-payload

CAMPIONE

66bddfcb52736_vidar.exe

FONTE SANDBOX

ANY.RUN — task 371957e1

SHA256

325396D5...5EA13B8D1

DATA ANALISI

25 Agosto 2024

AMBIENTE

Windows 10 Pro (build 19045, x64)

CLASSIFICAZIONE

Loader + Stealer (T1055)

VERDETTO

 **ATTIVITÀ MALEVOLA CONFERMATA**

#LOADER

#VIDAR

#LUMMA

#STEALER

#PROCESS-INJECTION

#REGASM.EXE

#C2-TELEGRAM

01 Sintesi Esecutiva

Il campione analizzato agisce come **loader**: al momento dell'esecuzione scarica ed avvia **due famiglie distinte di infostealer** — **Vidar** e **Lumma** — iniettandole in un processo legittimo di Windows per eludere i controlli di sicurezza. L'obiettivo finale è il furto sistematico di credenziali, cookie, dati di autofill, carte di pagamento salvate, wallet crypto, sessioni di Telegram/Discord/Steam e screenshot del desktop, con successiva esfiltrazione verso infrastrutture C2 controllate dagli attaccanti.

IMPATTO POTENZIALE

Compromissione totale delle credenziali salvate nel browser e negli account collegati (Discord, Telegram, Steam, email). I token rubati permettono il dirottamento degli account **senza necessità della password**.

Indicatori chiave

Indicatore	Dettaglio
Famiglie malware rilevate	Vidar Stealer, Lumma Stealer (rilevate sia da firme YARA che da regole Suricata)
Tecnica di evasione principale	Process Injection in <code>RegAsm.exe</code> (living-off-the-land binary Microsoft)
Canali C2	Telegram & Steam Community (dead-drop resolver) per Vidar; 8 domini <code>.shop</code> per Lumma
Processi coinvolti	5 processi malevoli generati dalla singola esecuzione iniziale
Auto-cancellazione	Sì — tramite <code>cmd.exe /c timeout & del/rd</code> per rimuovere le tracce

02 Catena di Esecuzione

L'infezione segue una struttura "a cascata" in cui il file iniziale dropa due binari mascherati, ciascuno dei quali inietta codice malevolo in una copia legittima di `RegAsm.exe` (Microsoft .NET Assembly Registration Utility).

```
66bddfcb52736_vidar.exe (PID 6780) — loader iniziale
|
|— scarica payload da 147.45.44.104 (RU) via HTTP
|
|—> CAFHDBGHJK.exe (PID 6248) "Auto File System Format Utility" (falso)
|   |—> RegAsm.exe (PID 6340) ▶ VIDAR STEALER
|
|—> HCAEHJJKFC.exe (PID 1568) "Auto File System Format Utility" (falso)
|   |—> RegAsm.exe (PID 6908) ▶ VIDAR STEALER (istanza principale)
|   |—> RegAsm.exe (PID 4704) ▶ LUMMA STEALER
```

OSSERVAZIONE TECNICA

Entrambi i dropper vengono scritti in `C:\ProgramData\` e si spacciano per un tool Microsoft chiamato "Auto File System Format Utility", con tanto di campi di versione e copyright falsificati — un classico caso di **masquerading (T1036)**.

03 Tecniche di Evasione e Anti-Analisi

3.1 — Process Injection su RegAsm.exe

`RegAsm.exe` è un binario legittimo e firmato Microsoft, normalmente usato per la registrazione di assembly COM .NET. Iniettando il proprio codice al suo interno, gli attaccanti fanno sì che il traffico di rete e le attività malevole risultino generate da un processo "attendibile" agli occhi di molte soluzioni EDR/antivirus basate su whitelist.

3.2 — Anti-Sandbox / Anti-VM Fingerprinting

Le stringhe estratte dal campione rivelano una serie di controlli tipici usati per rilevare ambienti di analisi automatizzata:

Indicatore	Significato
VMwareVMware	Rilevamento di macchine virtuali VMware tramite CPUID
HAL9TH / JohnDoe	Username/hostname placeholder tipici dei sandbox pubblici
GetSystemInfo / GlobalMemoryStatusEx	Verifica risorse hardware (CPU, RAM) troppo "pulite" per essere reali
GetKeyboardLayoutList / GetUserDefaultLocaleName	Fingerprint lingua e layout tastiera del sistema
NtQueryInformationProcess	Rilevamento debugger/hook a livello di processo

3.3 — Cancellazione delle tracce

Al termine dell'esfiltrazione viene lanciato `cmd.exe` con comandi come `timeout /t 10 & rd /s /q "C:\ProgramData\FHJDBKJKFIEC" & exit`, che ritardano ed eseguono la cancellazione della cartella di lavoro e dei DLL droppati — riducendo le evidenze forensi disponibili post-infezione.

04 Capacità di Furto Dati

4.1 — Browser (Chrome, Opera/GX, Firefox)

- **Credenziali salvate:** query dirette sui database `Login Data` (Chromium) e `logins.json` (Firefox)
- **Decrittazione:** `CryptUnprotectData` (DPAPI di Windows) per Chromium; libreria NSS (`nss3.dll` + `PK11SDR_Decrypt`) droppata appositamente per Firefox
- **Cookie di sessione** da `Cookies` / `cookies.sqlite`
- **Dati di autofill e cronologia** di navigazione
- **Carte di pagamento salvate:** nome intestatario, scadenza, numero cifrato
- **Wallet/estensioni crypto** tramite ricerca in `Local Extension Settings` e `IndexedDB`

4.2 — Applicazioni di messaggistica e gaming

Target	Dato rubato	Rischio
Telegram Desktop	File di sessione/chiavi locali (<code>D877F783D5D3EF8C*</code> , <code>map*</code>)	CRITICO accesso completo all'account senza credenziali

Discord	<code>tokens.txt</code> — token di autenticazione	CRITICO dirottamento account
Steam	<code>loginusers.vdf</code> , <code>ssfn*</code> , <code>config.vdf</code>	ALTO furto sessione/inventario
Outlook	Profili account da registro	ALTO
Pidgin / Tox	<code>accounts.xml</code> , <code>*.tox</code>	MEDIO

4.3 — System Fingerprint & Screenshot

Il malware cattura uno screenshot del desktop tramite le API GDI+ (`BitBlt`, `GdiSaveImageToStream`) e raccoglie hostname, username, specifiche CPU/RAM, lingua di sistema, fuso orario ed elenco software installato — tutti dati utili a profilare la vittima prima della vendita dei dati sui mercati underground.

05 Comando e Controllo / Esfiltrazione

I dati raccolti vengono impacchettati in richieste **HTTP POST multipart/form-data** con campi `hwid`, `build`, `token`, `file_name`, `file`, `message` — un formato compatibile con l'API Bot di Telegram, spesso usato per inviare i dati esfiltrati direttamente in una chat privata dell'attaccante.

5.1 — Vidar: Dead-Drop Resolver

Anziché contattare direttamente un server C2, Vidar visita un profilo **Telegram** o **Steam Community** la cui bio contiene (in forma offuscata) l'indirizzo reale del server C2. Questo rende l'infrastruttura resiliente: gli attaccanti possono cambiare il C2 aggiornando semplicemente il testo del profilo, senza dover ricompilare il malware.

Processo	Canale resolver	URL
RegAsm.exe (PID 6908)	Telegram	t.me/pech0nk
RegAsm.exe (PID 6908)	Steam	steamcommunity.com/profiles/76561199751190313
RegAsm.exe (PID 6340)	Telegram	t.me/jamelwt
RegAsm.exe (PID 6340)	Steam	steamcommunity.com/profiles/76561199761128941

5.2 — Lumma: Infrastruttura MaaS a rotazione

Lumma opera invece con una lista di domini C2 generati con pattern casuale su TLD `.shop`, tipico della sua natura *Malware-as-a-Service*, dove ogni "cliente" riceve build con set di domini che vengono ruotati periodicamente per eludere i blocklist.

TRAFFICO DI RETE RILEVATO

Connessione TLS verso `caffegclasiqwp.shop` classificata dalla regola Suricata "**STEALER Lumma Stealer TLS Connection**" — conferma indipendente della famiglia malware oltre alla firma YARA statica.

5.3 — Download payload aggiuntivi

Il loader iniziale scarica ulteriori eseguibili in chiaro (HTTP, non HTTPS) direttamente da un indirizzo IP nudo russo, comportamento raramente legittimo e per questo intercettato da più regole IDS:

Host	File scaricato	Dimensione	Alert IDS
147.45.44.104:80	66cb2df8bd684_lawrng.exe	321 KB	Executable Download from dotted-quad Host
147.45.44.104:80	66cb2df1d4a01_vakerk.exe	192 KB	SUSPICIOUS Dotted Quad Host MZ Response

06 Indicatori di Compromissione (IOC)

6.1 — File

Ruolo	Nome file	SHA256
LOADER	66bddfcb52736_vidar.exe	325396D5FFCA8546730B9A56C2D0ED99238D48B5E1C3C49E7D027505EA13B8D1

DROPPER	CAFHDBGHJK.exe / HCAEHJJKFC.exe	285BDCF03E3924D309ADD80E795B18678899977F518DA55937DE5DC0A68614C9
PAYLOAD	66cb2df8bd684_lawrng.exe	149D5C2949338ABB59F4FF360EA39229796C73F8E3A9C483442295A8E0F9FCC7

6.2 — Rete

Indicatore	Tipo	Note
147.45.44.104	IP malevolo	Host distribuzione payload (RU)
195.201.118.191	IP sospetto	Connessione da RegAsm.exe (Hetzner, DE)
condedqpwqm.shop	C2 Lumma	
stagedchheiqwo.shop	C2 Lumma	
traineiwnqo.shop	C2 Lumma	
locatedblsoqp.shop	C2 Lumma	
caffegclasiqwp.shop	C2 Lumma (confermato)	
evoliutwoqm.shop	C2 Lumma	
millyscroqwp.shop / stampreeowntnq.shop	C2 Lumma	
t.me/pech0nk, t.me/jamelwt	Resolver	Canali Telegram usati per risolvere il C2 reale
arpdabl.zapto.org	DynDNS sospetto	Risolto a 0.0.0.0 — probabile C2 secondario non più attivo

6.3 — Host

- Percorso anomalo: eseguibili droppati direttamente in C:\ProgramData\
- Librerie legittime abusate (scaricate per decifrare i dati di Firefox): nss3.dll, mozglue.dll, freebl3.dll, softokn3.dll, vcruntime140.dll, msvcpr140.dll
- Cartella temporanea di staging: C:\ProgramData\FHJDBKJKFIEC\ (nomi file casuali a 6 lettere maiuscole)

07 Mappatura MITRE ATT&CK

Tattica	ID	Tecnica
Execution	T1204	User Execution — la vittima avvia manualmente il loader
Defense Evasion	T1055	Process Injection in RegAsm.exe
Defense Evasion	T1036	Masquerading — nome/versione file falsificati come "Microsoft"
Defense Evasion	T1070.004	File Deletion — autocancellazione post-esfiltrazione
Discovery	T1082	System Information Discovery
Discovery	T1497	Virtualization/Sandbox Evasion
Discovery	T1518	Software Discovery
Credential Access	T1555.003	Credentials from Web Browsers
Credential Access	T1539	Steal Web Session Cookie
Collection	T1113	Screen Capture
Collection	T1005	Data from Local System
Command & Control	T1102	Web Service — Telegram/Steam come dead-drop resolver
Command & Control	T1071.001	Application Layer Protocol (HTTP/HTTPS)
Exfiltration	T1041	Exfiltration Over C2 Channel

08 Raccomandazioni Difensive

1. **Blocco di rete immediato** di tutti gli IP e domini elencati nella sezione IOC (§6.2), a livello di firewall perimetrale e proxy DNS.
2. **Monitoraggio comportamentale di RegAsm.exe**: qualsiasi connessione di rete in uscita generata da questo processo è altamente anomala e va trattata come indicatore di compromissione critico.
3. **Alert su eseguibili avviati da C:\ProgramData**, percorso raramente utilizzato da software legittimo installato dall'utente finale.
4. **Rotazione completa delle credenziali** su tutte le macchine potenzialmente compromesse: browser, email, Telegram, Discord, Steam.
5. **Revoca dei token** Discord e delle sessioni Telegram/Steam esposte, poiché consentono l'accesso agli account senza necessità della password.
6. **Deployment delle firme YARA/Suricata** già disponibili per Vidar e Lumma su tutti gli endpoint EDR aziendali.
7. **User awareness**: rinforzare la formazione su phishing/social engineering, principale vettore di distribuzione noto per entrambe le famiglie.

Report generato a partire esclusivamente dai dati dell'analisi sandbox ANY.RUN forniti. Non è stata condotta un'analisi statica/dinamica indipendente del binario. Documento a scopo di analisi difensiva e threat intelligence interna.